

5. Testarea securității rețelelor



Scopul testelor de securitate

- **Feedback cu privire la eficiența măsurilor de securitate implementate**
 - îmbunătățire continuă a securității sistemelor
- **Demonstrarea complianței cu standardele și reglementările în vigoare**
- **Activitate repetitivă**
- **Abordări:**
 - Vulnerability Scanning
 - Penetration Testing / Etical Hacking
- **Metodologii**
 - Open Source Security Testing Methodology Manual (OSSTMM)
 - NIST SP 800-115 “Technical Guide to Information Security Testing and Assessment”

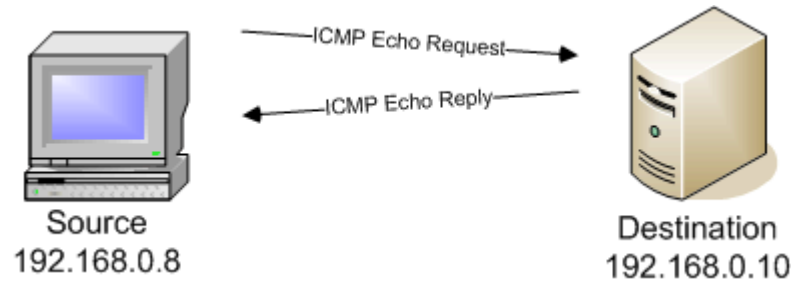
Unelte uzuale

- Scanere de porturi
- Scannere de vulnerabilități
- ...

Scanere de porturi

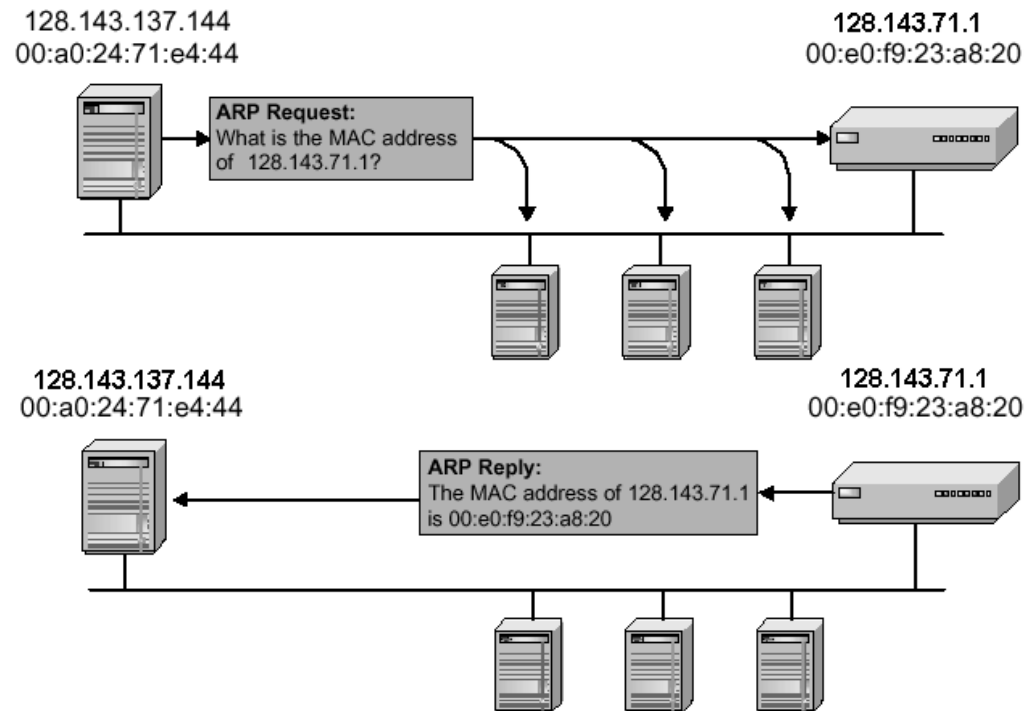
- **Identificarea calculatoarelor active din rețea, determinarea porturilor de deschise și a serviciilor asociate**
- **Culegere de informații despre rețea (network mapping tool)**
- **Tehnici de scanare:**
 - ICMP Ping
 - ARP Ping
 - TCP connect() Scan
 - TCP SYN Scan
 - TCP FIN, Xmas Tree, Null Scan
 - UDP Scan

ICMP Ping



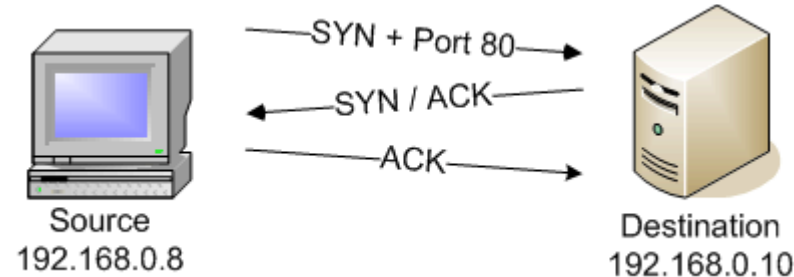
- **Interogări ICMP**
 - ICMP ECHO_REQUEST (Type 8)
 - ICMP ECHO_REPLY (Type 0)
- **Poate fi blocat de network firewall / personal firewall**
- **Unelte:**
 - ping / fping
 - nmap -PE
 - hping3 --icmp

ARP Ping



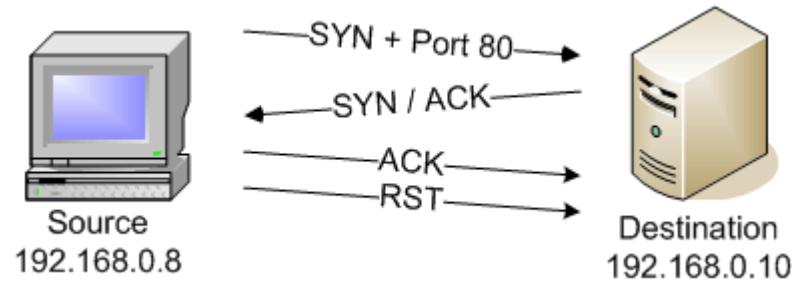
- Permite descoperirea numai a sistemelor din rețeaua locală
- Unele:
 - arping
 - nmap -PR

Scanare porturi TCP



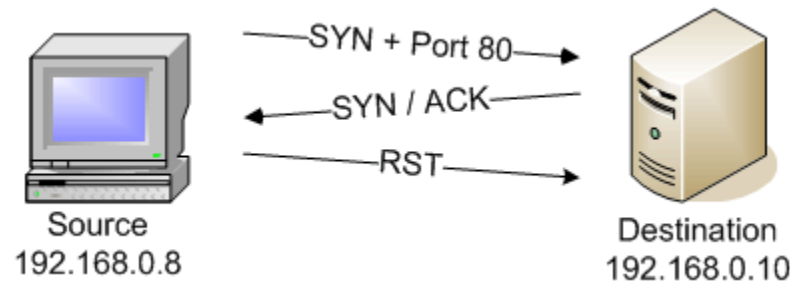
- Deschiderea unei conexiuni se face prin **three-way handshake**
 - SYN -> SYN+ACK -> ACK
- Se trimite un pachet cu flagul SYN setat
 - dacă ținta răspunde cu SYN+ACK, atunci portul este *deschis (open)*
 - dacă țintă răspunde cu RST, atunci portul este *închis (closed)*
 - dacă ținta nu răspunde, atunci portul este *filtrat (filtered)*

TCP Connect() Scan



- Metodă de scanare simplă și rapidă
- Creează conexiuni TCP complete
- Apelurile connect() sunt jurnalizate
netstat
- Unele:
telnet
nmap -sT

TCP SYN Scan

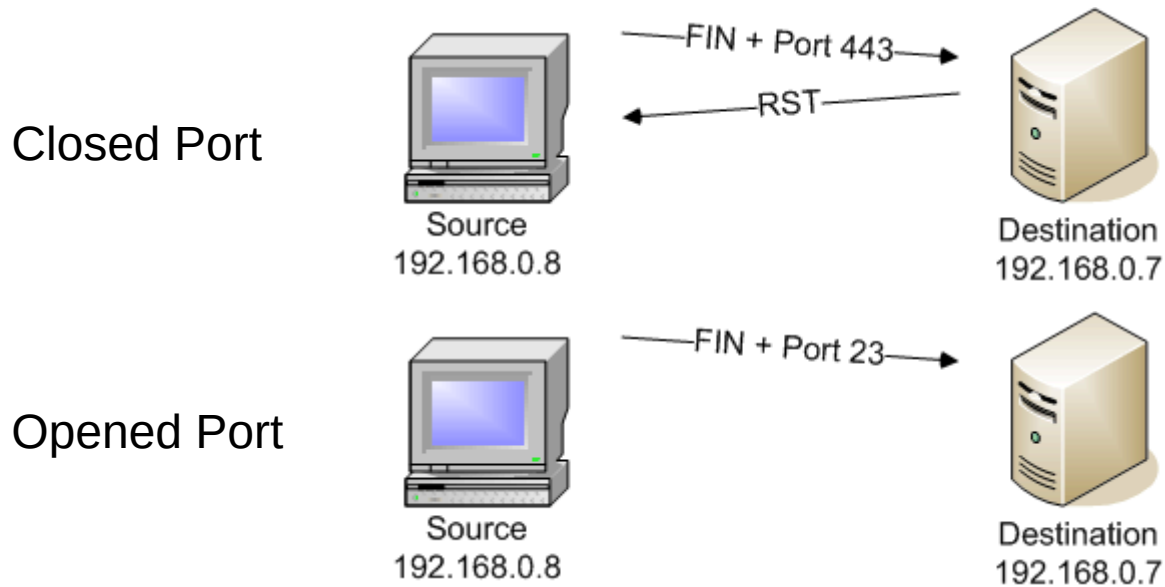


- **Conexiuni pe jumătate deschise (half open connection)**
 - se transmite un pachet SYN pentru a cere deschiderea conexiunii
 - după recepționarea unui SYN/ACK se renunță la conexiune trimițându-se un pachet RST
- **Greu de detectat**
 - majoritatea IDS și firewall-urilor nu interpretează pachetele SYN
- **Unelte:**
 - # nmap -sS
 - # hping3 --syn

TCP FIN, Xmas Tree, Null Scan

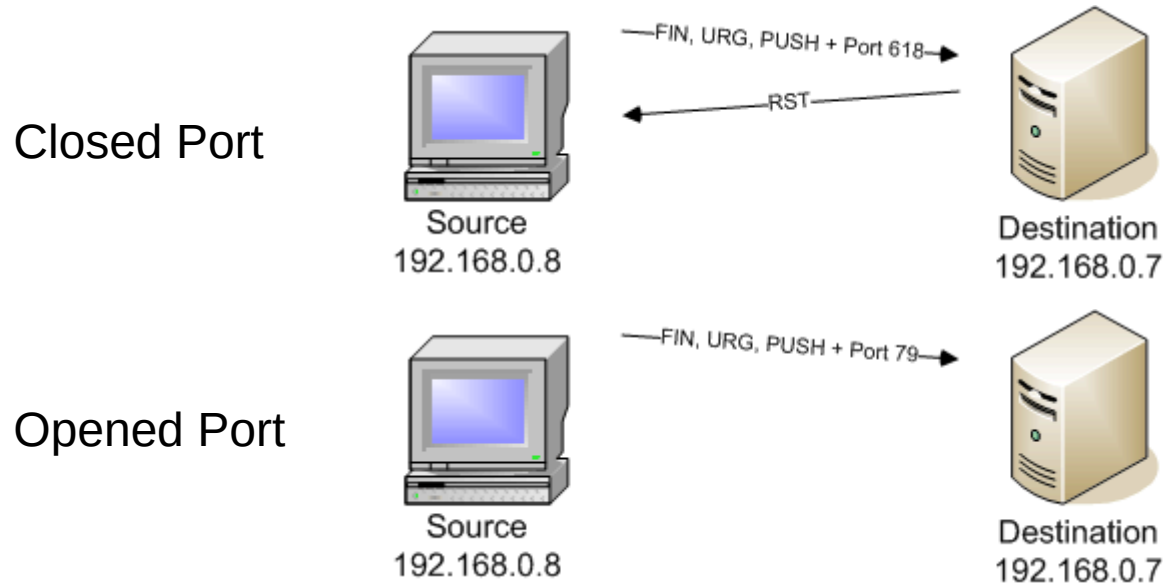
- **Principiul de funcționare este același**
 - manipularea biților de control (flags) din antetul pachetelor TCP
 - pachete atipice (ce nu pot și întâlnite în realitate)
- **Conform RFC 793, atunci când un sistem primește un pachet pe un port închis, trebuie să răspundă cu un RST**
 - dacă nu se recepționează nici un RST înseamnă că portul este deschis sau comunicația este filtrată de firewall
- **Nu funcționează în cazul sistemelor Windows, Cisco, IBM OS/400 (returnează RST chiar dacă portul este deschis)**

TCP FIN Scan



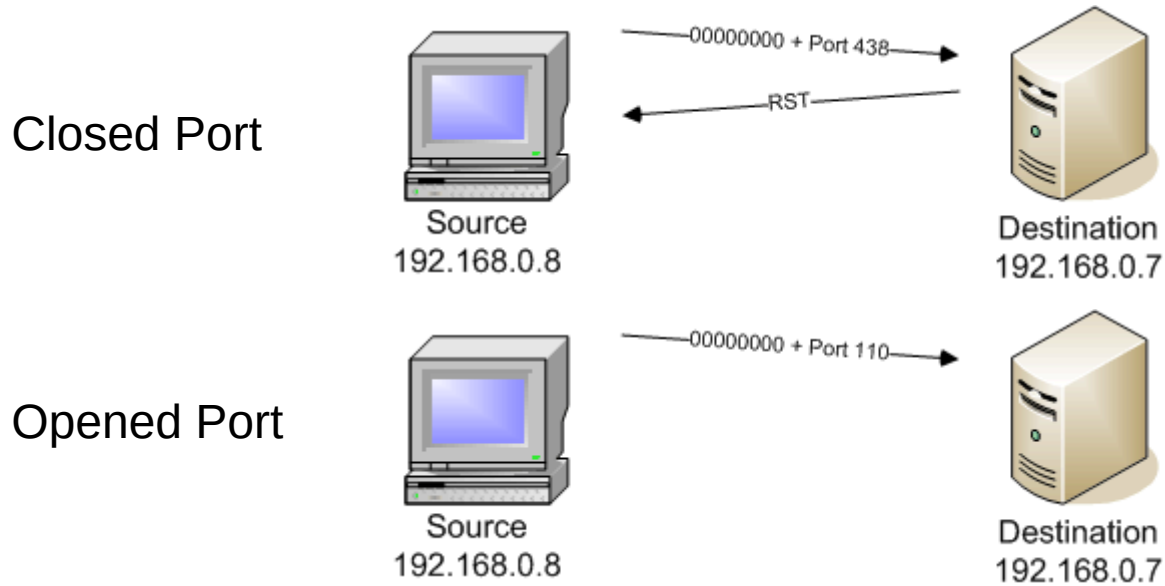
- Se trimite din prima un pachet TCP având flag-ul FIN setat
- Unele:
 - nmap -sF
 - hping3 --fin

TCP Xmas Tree Scan



- Se trimite din prima un pachet TCP având flag-urile FIN, URG și PUSH setate
- Unelte:
 - nmap -sX
 - hping3 --fin --urg --push

TCP Null Scan



- Se trimite din prima un pachet TCP fără nici un flag setat
- Unele:
 - nmap -sN
 - hping3

Alte scanări TCP

■ TCP ACK Scan

- folosit pentru a determina tipul de firewall (stateless / stateful) și porturile filtrate de acesta
- dacă firewall-ul este stateless și accesul la sistem este permis, porturile deschise și închise vor returna RST

nmap -sA

■ TCP Window Scan

- Similar cu TCP ACK Scan
- examinarea dimensiunii ferestrei TCP din pachetele RST primite ca răspuns. Dacă dimensiunea ferestrei este diferită de zero, portul este deschis

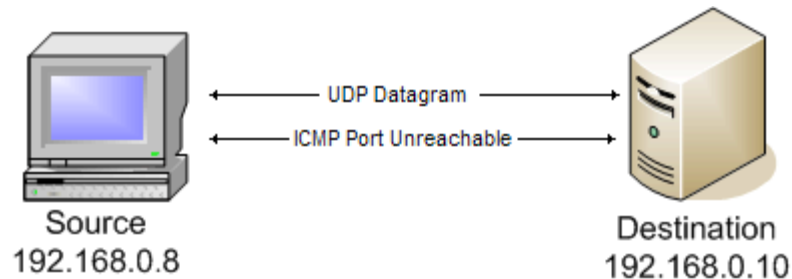
nmap -sW

■ TCP Idle Scan

- scanare indirectă prin intermediul unui zombie

nmap -sl

UDP Scan



- Similar unui TCP scan dar cu pachete UDP
- Se transmit pachete UDP către porturile de pe calculatorul țintă. Dacă nu apare nici o eroare ICMP atunci portul este posibil să fie deschis sau filtrat de firewall
- Proces lent
 - timp de răspuns mare 1-4 sec
- Unelte:
 - # nmap -sU
 - # hping3 --udp

OS Fingerprinting

- **RFC-urile nu conțin specificații complete**
- **Diferențe subtile în implementarea stivei TCP/IP**
 - TTL (time-to-live)
 - Numerele de secvență inițiale
 - Window size
 - DF (Don't fragment bit)
 - ...
- **Passive fingerprinting**
 - analiza pachetelor care trec prin dreptul stației de observare
 - precizie scăzută
- **Active fingerprinting**
 - trimiterea de pachete către țintă pentru a vedea cum se comportă
 - precizie ridicată

Passive OS fingerprinting

- p0f (<http://lcamtuf.coredump.cx/p0f.shtml>)
- Analiza pachetelor TCP transmise de stații
- p0f output

```
<Wed Feb 27 18:26:58 2008> 213.215.x.x:45291 - Linux 2.6
  (newer, 2) (up: 1421 hrs) -> 208.83.x.x:2703 (distance 0,
  link: ethernet/modem)

<Wed Feb 27 18:27:02 2008> 212.24.x.x:62994 - FreeBSD 5.3-
  5.4 (up: 4556 hrs) -> 213.215.x.x:80 (distance 9, link:
  ethernet/modem)

<Wed Feb 27 18:27:16 2008> 90.2.x.x:1322 - Windows 2000 SP4,
  XP SP1+ -> 213.215.x.x:80 (distance 9, link: pppoe (DSL))
```

Active OS fingerprinting

- nmap -O
- 7 probe TCP, 1 ICMP, 1 UDP, la interval de 110 milisecunde



The screenshot shows a terminal window with a menu bar (Session, Edit, View, Bookmarks, Settings, Help) and a title bar. The terminal content is as follows:

```
root@1[knoppix]# nmap -O 10.0.0.10

Starting nmap 3.75 ( http://www.insecure.org/nmap/ ) at 2005-11-14 21:13 EST
Interesting ports on server.homelan.net (10.0.0.10):
(The 1653 ports scanned but not shown below are in state: closed)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3306/tcp  open  mysql
MAC Address: 00:02:B3:41:08:B8 (Intel)
Device type: general purpose
Running: Linux 2.4.X|2.5.X|2.6.X
OS details: Linux 2.4.0 - 2.5.20, Linux 2.4.18 - 2.6.7

Nmap run completed -- 1 IP address (1 host up) scanned in 2.567 seconds
root@1[knoppix]#
```

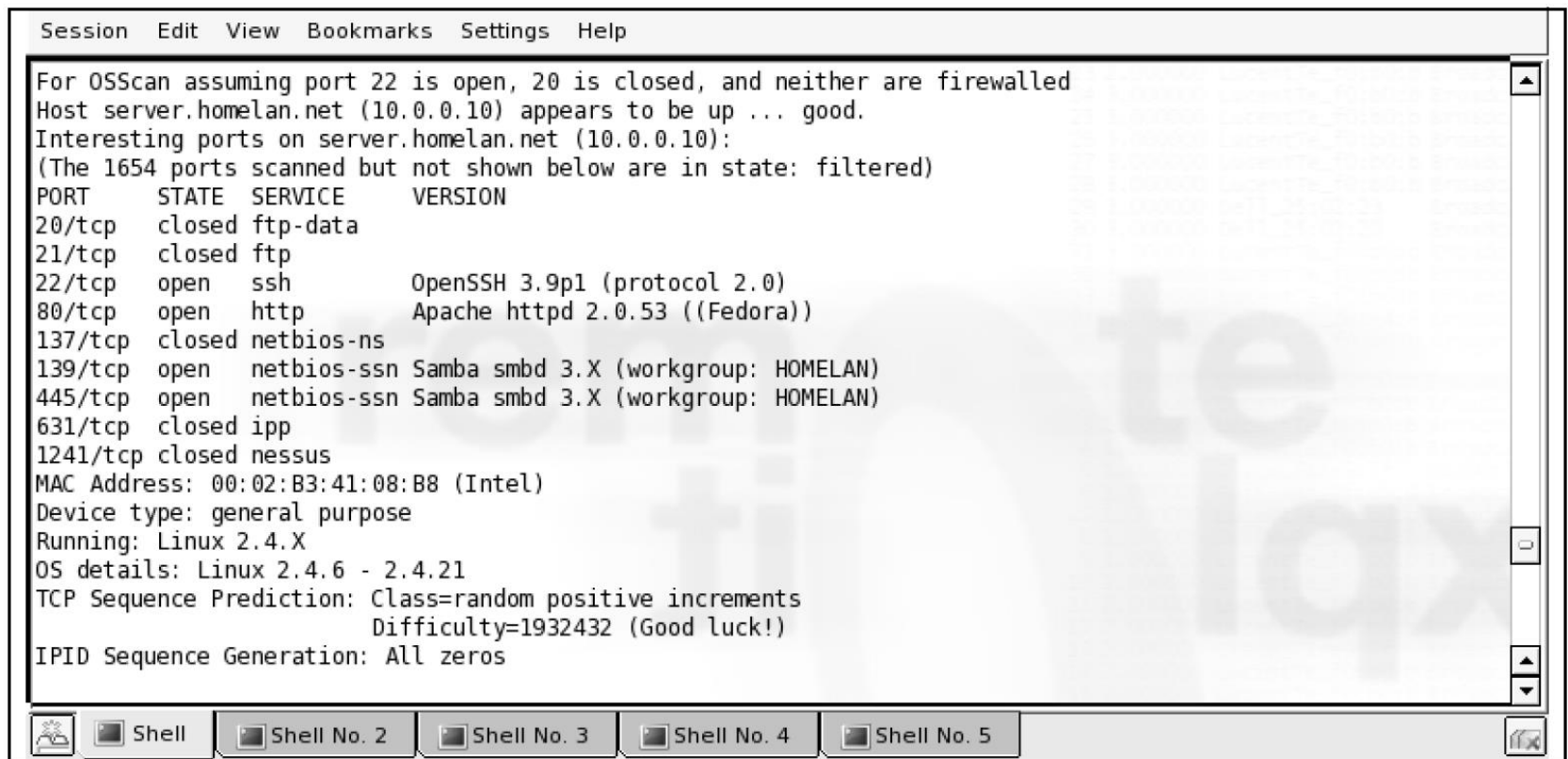
The terminal window has a status bar at the bottom with a 'Shell' button and a small icon on the right.

Identificarea serviciilor

- **Banner grabbing**
 - foarte multe servicii “se prezintă” în momentul conectării
 - Apache/2.4.41 (Ubuntu)
 - SSH-2.0-OpenSSH_7.9p1 Debian-10
- **Amprentare**
 - transmiterea de pachete personalizate și compararea răspunsului cu o bază de date cu semnături
- **Unelte:**
 - # telnet
 - # nmap
 - # amap
 - # httpprint

Banner Grabbing (cont.)

- **nmap -sV**
- **Detectarea versiunii serviciilor**



```
Session Edit View Bookmarks Settings Help

For OSScan assuming port 22 is open, 20 is closed, and neither are firewalled
Host server.homelan.net (10.0.0.10) appears to be up ... good.
Interesting ports on server.homelan.net (10.0.0.10):
(The 1654 ports scanned but not shown below are in state: filtered)
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    closed ftp
22/tcp    open  ssh          OpenSSH 3.9p1 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.0.53 ((Fedora))
137/tcp   closed netbios-ns
139/tcp   open  netbios-ssn Samba smbd 3.X (workgroup: HOMELAN)
445/tcp   open  netbios-ssn Samba smbd 3.X (workgroup: HOMELAN)
631/tcp   closed ipp
1241/tcp  closed nessus
MAC Address: 00:02:B3:41:08:B8 (Intel)
Device type: general purpose
Running: Linux 2.4.X
OS details: Linux 2.4.6 - 2.4.21
TCP Sequence Prediction: Class=random positive increments
                      Difficulty=1932432 (Good luck!)
IPID Sequence Generation: All zeros
```

Shell Shell No. 2 Shell No. 3 Shell No. 4 Shell No. 5

Vulnerabilități

- Eroare de programare sau greșeală de configurare ce poate crea breșe în securitatea sistemelor
- Dacă nu sunt corectate la timp pot fi exploatare de către un eventual atacator
- Metode de corecție
 - instalare de patch-uri recomandate de producător
 - securizarea sistemelor (hardening)

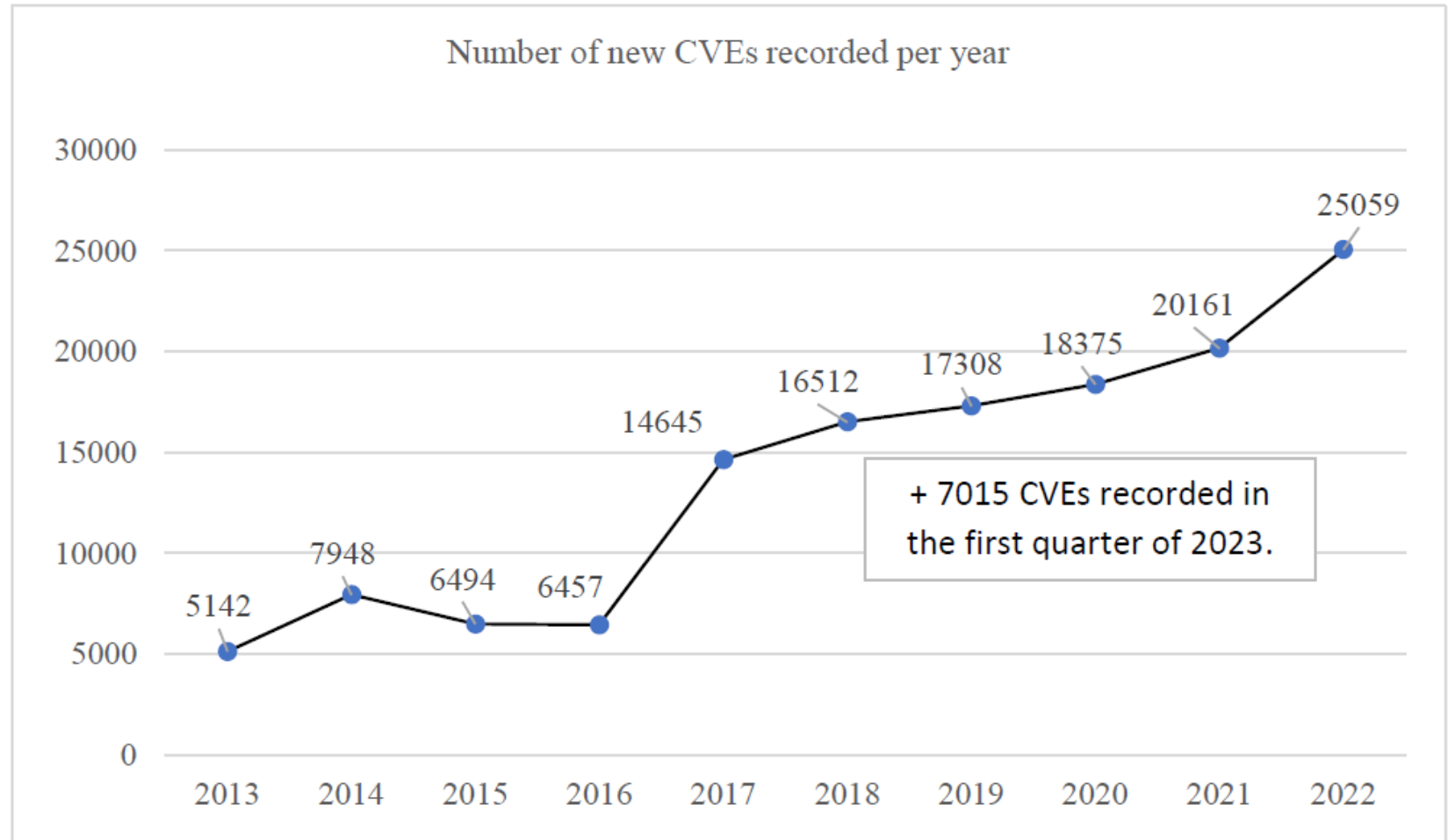
Vulnerabilități (cont.)

- Validarea insuficientă a datelor de intrare
- Ocolirea mecanismelor de autentificare
- Expunerea datelor senzitive
- Buffer Overflow
- Coruperea Heap-ului
- ...

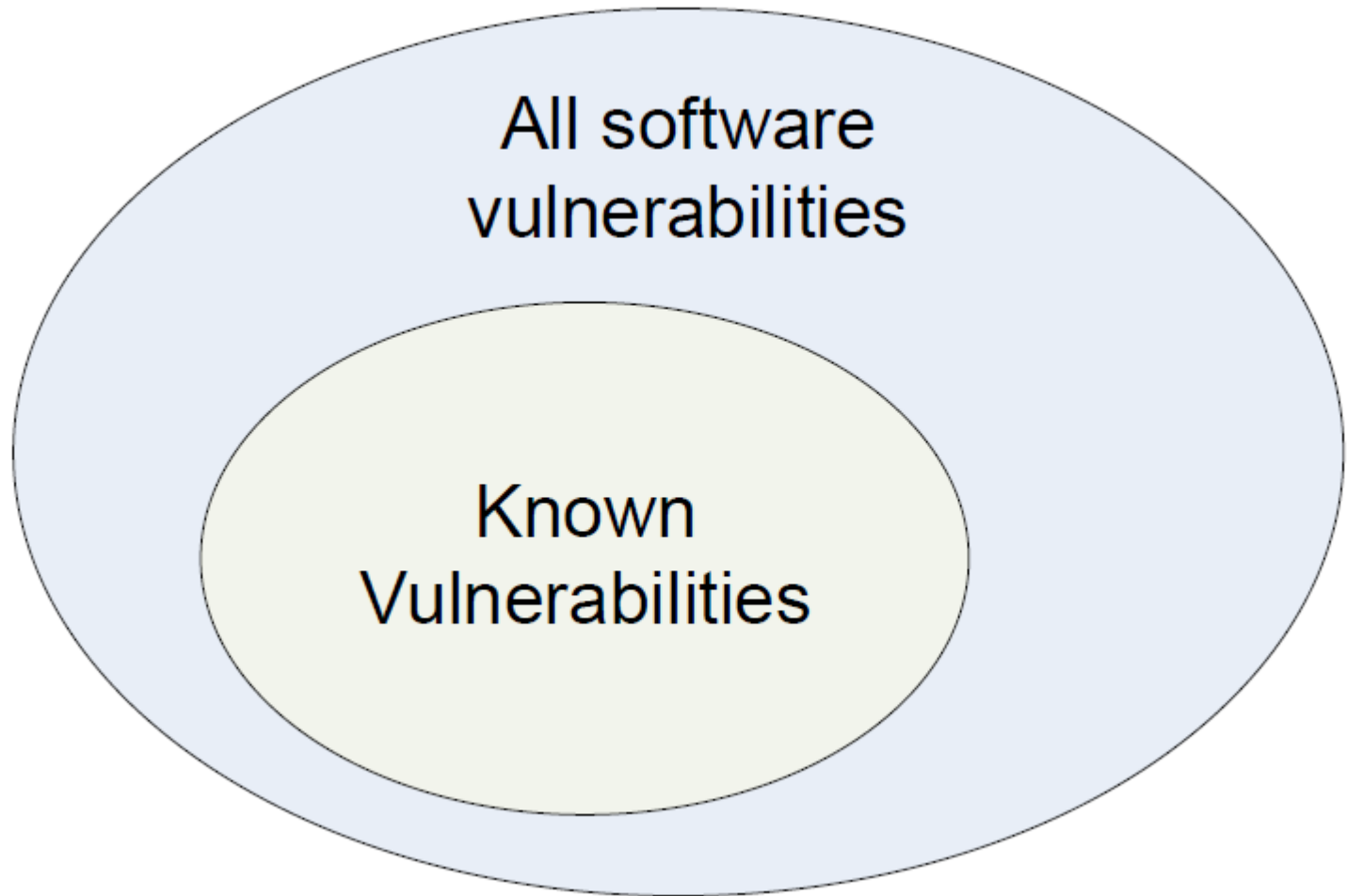
Vulnerabilități (cont.)

- Peste 100.000 vulnerabilități cunoscute
- Common Vulnerabilities and Exposures (CVE)
 - lista cu denumirile standardizate ale tuturor vulnerabilităților cunoscute
 - dicționar de vulnerabilități (nu bază de date)
 - <http://cve.mitre.org/>
- Baze de date de vulnerabilități
 - National Vulnerability Database (<http://nvd.nist.gov/>)
 - Secunia Advisory and Vulnerability Database (<http://secunia.com/>)
 - Open Source Vulnerability Database (<http://osvdb.org/>)
 - SecurityFocus (<http://www.securityfocus.com/>)

Vulnerabilități (cont.)



Vulnerabilități (cont.)



Tehnici de descoperire a vulnerabilităților

- **Static structural analysis**
 - Source code review
 - Binary code analysis / Reverse code engineering
- **Dynamic structural testing**
 - înregistrarea apelurilor de funcții efectuate de aplicație
- **Fuzz testing**
 - testarea aplicațiilor folosind date de intrare invalide / aleatoare
 - testare negativă

Scannere de vulnerabilități

- **Automatizarea procesului de identificare și corectare a vulnerabilităților**
 - permit detectarea numai a vulnerabilităților cunoscute!
- **Clasificare**
 - funcție de locație de unde se face scanarea
 - network based
 - host based
 - funcție de credențialele folosite pe parcursul scanării
 - cu drepturi administrative
 - fără drepturi administrative
 - funcție de tipul de sisteme / aplicații testate
 - de uz general
 - pentru aplicații web

Scannere de vulnerabilități (cont.)

- OpenVAS (<https://www.openvas.org/>)
 - Nuclei (<https://github.com/projectdiscovery/nuclei>)
 - Nessus (<https://www.nessus.org>)
 - Rapid7 Nexpose (<https://www.rapid7.com/>)
 - GFI LANGuard (<https://www.gfi.com>)
 - QualysGuard (<https://www.qualys.com/>)
- <https://sectools.org/tag/vuln-scanners/>

Resurse utile

- **NIST Special Publications**
 - <http://csrc.nist.gov/publications/nistpubs/>
- **NSA Security Configuration Guides**
 - <http://www.nsa.gov/snac/>
- **Center for Internet Security**
 - <https://www.cisecurity.org/>
- **Security Onion Distro**
 - colecție de unelte pentru monitorizarea securității rețelelor
 - <https://securityonionsolutions.com/>

